

← ↺ ☆

Implementation Defect: UI "Delete" Fails to Trigger Immediate Server-Side Cascade Purge in Interactions API (CWE-459)

+1

Hotlists

Mark as Duplicate

🔔

⋮

Comments (7)

Dependencies (0)

Duplicates (0)

Blocking (0)

Resources (6)

WAI

Customer Issue

P4

+ Add Hotlist

👤

STATUS UPDATE

No update yet.

📄

DESCRIPTION

bu...@google.com created issue on behalf of György Istókolics #1

Oct 2, 2026 06:02AM

⋮

Summary: Implementation Defect: UI "Delete" Fails to Trigger Immediate Server-Side Cascade Purge in Interactions API (CWE-459)

Program: Google VRP

URL: google ai studio, google drive

Vulnerability type: Other

Details

Title: Implementation Defect: UI "Delete" Fails to Trigger Immediate Server-Side Cascade Purge in Interactions API (CWE-459) Program: AI VRP / Google VRP Vulnerability Type: Sensitive Data Exposure / Broken Access Control (CWE-459)

1. Summary & Core Defect: A severe software implementation defect exists in Google AI Studio. The user interface explicitly promises immediate and irreversible data destruction upon clicking "Delete" and emptying the Google Drive Trash. However, the client-side UI action terminates strictly at the Drive level (affecting only the .json pointer file) and sends ZERO cascade deletion signals (DELETE/DROP) to the backend database (Interactions API). The server-side session object, conversational context, and tokens remain fully active and cached in hot storage immediately after the deletion command.
2. Steps to Reproduce (Immediate PoC): Open Google AI Studio and create a prompt session containing sensitive test data. Click the "Delete" button on the chat session. Open Google Drive Trash and click "Empty Trash" (the UI explicitly confirms: "Item permanently deleted and cannot be recovered"). Immediately run the Google Drive File Recovery tool to restore the discarded .json pointer file. Launch Google AI Studio and open the restored file. Observed Result: The complete conversation history, model state, and private tokens reload instantly from the backend with zero latency, proving the server never executed a deletion command. Expected Result: The backend database should execute an immediate cascading purge upon the deletion command, resulting in an unrecoverable 404 Not Found state.
3. Why this is an Implementation Bug (Not Intended Behavior): The system advertises immediate permanent destruction on the UI, but the code fails to implement the required cross-service API call between Google Drive and the Interactions API backend. Decoupling the UI deletion from the backend datastore without a cascade drop is an implementation flaw (CWE-459: Incomplete Cleanup), leaving user data permanently exposed on production storage. Pre-emptive Technical Clarification Regarding "Intended Behavior" This issue cannot be classified as "Intended Behavior" or "Out of Scope" based on the following technical facts: The user interface explicitly informs the user that emptying the trash results in permanent, irreversible destruction. The API specification documents automated purging via TTL mechanisms. Retaining live, unencrypted conversational state in active storage when the client interface asserts permanent destruction constitutes an implementation flaw in data lifecycle management, not an authorized disaster recovery backup (as the data remains in active "hot storage").

Reporter

 istokovicsgyorgy79@gmail.com

Type

 Customer Issue

Priority

P4

Severity

S4

Status

Won't fix (Intended behavior)

Access

Default access View

Expanded Access

?

Assignee

Verifier

Collaborators

 _____ ^

CC

 _____ ^
istokovicsgyorgy79@gmail.com
wo...@google.com
Un-CC me

Code Changes

--

Pending Code Changes

--

Disclosure information

--

Reporter e-mail

--

Requested charity

--

Attack scenario

- 2. Steps to Reproduce (Immediate PoC): Open Google AI Studio and create a prompt session containing sensitive test data. Click the "Delete" button on the chat session. Open Google Drive Trash and click "Empty Trash" (the UI explicitly confirms: "Item permanently deleted and cannot be recovered"). Immediately run the Google Drive File Recovery tool to restore the discarded .json pointer file. Launch Google AI Studio and open the restored file. Observed Result: The complete conversation history, model state, and private tokens reload instantly from the backend with zero latency, proving the server never executed a deletion command. Expected Result: The backend database should execute an immediate cascading purge upon the deletion command, resulting in an unrecoverable 404 Not Found state.
- 3. Why this is an Implementation Bug (Not Intended Behavior): The system advertises immediate permanent destruction on the UI, but the code fails to implement the required cross-service API call between Google Drive and the Interactions API backend. Decoupling the UI deletion from the backend datastore without a cascade drop is an implementation flaw (CWE-459: Incomplete Cleanup), leaving user data permanently exposed on production storage. Pre-emptive Technical Clarification Regarding "Intended Behavior" This issue cannot be classified as "Intended Behavior" or "Out of Scope" based on the following technical facts: The user interface explicitly informs the user that emptying the trash results in permanent, irreversible destruction. The API specification documents automated purging via TTL mechanisms. Retaining live, unencrypted conversational state in active storage when the client interface asserts permanent destruction constitutes an implementation flaw in data lifecycle management, not an authorized disaster recovery backup (as the data remains in active "hot storage").

Report Analysis

Note: The feedback below was generated as part of an automated analysis of the submitted report. It is *NOT* part of the report that was submitted by the user.

Intended Behavior

The reported behavior appears to be intended. Please check the documentation.

 **K-perny-k-p-2026-08-30-085302.png** 

403 KB [View](#) [Download](#) 

 **Képernyőkép 2026-08-30 085302.png** 

403 KB [View](#) [Download](#) 

 **Képernyőkép 2026-09-06 191250.png** 

262 KB [View](#) [Download](#) 

Found In --

Targeted To --

Verified In --

In Prod 

COMMENTS



sp...@google.com <sp...@google.com> [#2](#)

All comments 

↓ Oldest first

Comment added. Oct 2, 2026 06:03AM 

NOTE: This is an automatically generated email

Hi! Many thanks for sharing your report.

This email confirms we've received your message. We'll investigate the issue you've reported and get back to you once we have an update. In the meantime, you might want to take a look at the [list of frequently asked questions about Google Bug Hunters](#).

Also, if you have not already done so, create a profile on [the Google Bughunters site](#) if you'd like us to publicly recognize your contribution:

- [Leaderboard](#) – You'll be added here if we issue a reward for your report.
- [Honorable Mentions](#) – You'll be added here if you are not in the Hall of Fame, but we file a security vulnerability bug based on your report.

Note that we only act on reports concerning vulnerabilities or technical security problems in one of our products. This is not the correct channel if you need to resolve a problem with your account, or want to report non-security bugs or suggest a new product feature.

Cheers,
Google Security Bot

[Follow us](#) on Twitter!



György Istókovics <istokovicsgyorgy79@gmail.com> [#3](#)

Oct 2, 2026 06:03AM ⋮

ne merjétek lezárni!



György Istókovics <istokovicsgyorgy79@gmail.com> [#4](#)

Oct 2, 2026 06:03AM ⋮

Do Not closed!!!!



sp...@google.com <sp...@google.com> [#5](#)

Oct 2, 2026 06:04AM ⋮

Status: Won't Fix (Intended Behavior).

NOTE: This is an automatically generated email

Our Vulnerability Reward Programs (VRPs) are built on key pillars of respect, constructive collaboration, and good faith to ensure a professional environment. These principles are formalized in our [Code of Conduct](#) which all participants are expected to uphold.

A review has determined that activity associated with your account is inconsistent with these principles and constitutes a **violation of the Code of Conduct**.

Therefore, in line with our stated enforcement policy, **your account has been permanently excluded from our VRPs, and we will no longer review or act on any new submissions from your account, including this one.** Please be aware that we will not see any replies to this or other future reports. This action is final and not open to appeal.

Comment added.



For a detailed explanation of our community standards and prohibited behaviors, please refer to the full [Code of Conduct](#) document.

Sincerely,
Google Security Bot



György Istókovics <istokovicsgyorgy79@gmail.com> [#6](#)

Oct 2, 2026 06:04AM ⋮

Ha automata zárást kapok akkor robot ír tehát csalás!!!



György Istókovics <istokovicsgyorgy79@gmail.com> [#7](#)

Oct 2, 2026 06:05AM ⋮

köszönöm szépen megtettem a rendőrségi feljelentést is a mai napon!

Comment added.

